Access Control

Objectives:

At the end of this episode, I will be able to:

1. Identify access control methods.

Exam Objective: *3.3 - Explain important concepts pertaining to identity and access management for server administration.*

Description: In this episode, the viewer will identify various methods to implement access control such as role-based, rule-based, and scope based access control as well as segregation of duties and delegation.

- Defines and controls access to resources
- Mandatory
  - Administratively defined
  - Most strict
  - Expensive
  - Classification (sensitivity levels) and authorization levels ()
  - Examples
    - Military
    - Windows (Mandatory Integrity Control)
      - processes (trust levels)
      - User (admin vs. standard users)
      - Hybrid (ILs/User + ACL inspection)

- Discretionary
  - Only user defined
    - However, administrator access
  - Examples
    - File and folder permissions (NTFS, Linux/Unix-like)

      ```
      Demo NTFS ACLs
      Demo Linux permissions
      ```

- Role-based
  - Non-discretionary
  - Administratively defined
  - Scope-based
    - RBAC extension/subset
    - RBAC extension
  - Examples:
    - Windows and Linux Groups
    - Windows Nested Groups (scope-based)
  - Segregation of duties

    ```
    Demo via *Developers* and *Marketing* group (use ACLs over shared
    folder)
    Demo scope-based via delegation of groups to Department managers for
    each department/role (Use Active Directory to delegate "group" OUs)
    ```

- Rule-based
    - Administratively defined
    - Firewall rules (if it is this, then do that)
    - Attribute-based
        - Advanced rule-based (if this, and this, and this...then that, and that, and that)

External Resources:

During this episode, you can reference the following external resources for supplementary tools and information:

- Not applicable if blank